

UNIT 1: INTRODUCTION TO COMPUTER SECURITY

1.1 Foundations of Computer Security

Computer Security

Computer Security is the process of protecting computer systems, networks, software, and data from unauthorized access, misuse, damage, theft, or disruption.

Example: A bank uses passwords, encryption, and firewalls to protect customers' account information from hackers.

Need of Computer Security

1. Protects Confidential Information

Protects sensitive information from unauthorized access or disclosure.

Example: A hospital protects patients' medical records so that only doctors can access them.

2. Prevents Unauthorized Access

Ensures that only authorized users can access computer systems and data.

Example: Employees log in to the company system using a username and password.

3. Ensures Data Integrity

Keeps data accurate, complete, and free from unauthorized modifications.

Example: A student's examination marks cannot be changed by anyone except the examination department.

4. Protects Against Malware and Hackers

Safeguards computers from viruses, ransomware, worms, and cyberattacks.

Example: Antivirus software detects and removes a virus before it damages the computer.

5. Prevents Financial Loss

Reduces financial losses caused by cybercrime, fraud, and data theft.

Example: An online banking system uses encryption to prevent hackers from stealing customers' money.

6. Builds Customer Trust

Increases customers' confidence that their personal and financial information is secure.

Example: Customers trust an e-commerce website because it securely processes online payments.

Advantages

- Protects confidential information.
- Prevents cyber-attacks.
- Reduces financial losses.
- Builds customer trust.

Disadvantages

- High implementation cost.
- Requires regular updates.
- May slow system performance.
- Needs skilled professionals.

Security Basics

1. Confidentiality

Confidentiality is the security principle that ensures information is accessible **only to authorized users** and is protected from unauthorized access, disclosure, or theft. It prevents sensitive data from being viewed by people who do not have permission. **Methods to Maintain**

Confidentiality: Passwords, Encryption, Access Control Lists (ACLs), Multi-Factor Authentication (MFA), File Permissions

Example: Only the HR department can access employees' salary records, while other employees cannot view them.

2. Integrity

Integrity is the security principle that ensures data remains **accurate, complete, and unchanged** throughout its lifecycle. It prevents unauthorized users from modifying, deleting, or corrupting information and ensures that any authorized changes are properly recorded. **Methods to**

Maintain Integrity: Hash Functions, Digital Signatures, File Permissions

Example: Only the examination department can update students' marks, preventing unauthorized modification.

3. Availability

Availability is the security principle that ensures computer systems, applications, networks, and data are **accessible to authorized users whenever they are needed**. It protects against system failures, hardware problems, cyberattacks, and natural disasters that may interrupt services.

Methods to Maintain Availability: Regular Data Backups, Redundant Servers, Disaster Recovery Plans, Load Balancing

Example: Customers should be able to access online banking services at any time without interruption.

4. Accountability

Accountability is the security principle that ensures **every action performed on a computer system can be traced back to the user who performed it**. It holds users responsible for their activities and helps detect unauthorized actions through logs and audit records. **Methods to**

Maintain Accountability: User IDs, Audit Logs, Activity Monitoring, System Logging, Access Records

Example: A company's server records which employee logged in, what files were accessed, and what changes were made.

5. Nonrepudiation

Nonrepudiation is the security principle that ensures a **sender cannot deny sending a message or performing a transaction, and the receiver cannot deny receiving it**. It provides proof of the origin and delivery of data, making electronic transactions legally reliable. **Methods to Maintain Nonrepudiation:** Digital Signatures, Digital Certificates, Secure Audit Logs

Example: When a customer digitally signs an online banking transaction, they cannot later deny authorizing the payment.

6. Reliability

Reliability is the security principle that ensures a computer system **performs its intended functions correctly, consistently, and without unexpected failures** over a long period. A reliable system provides accurate results and remains operational even when minor faults occur. **Methods to Improve Reliability:** Fault-Tolerant Systems, Regular Maintenance, Error Detection and Correction.

Example: Cloud storage services like Google Drive continue to work even if one server fails because other backup servers take over.

7. Authentication

Authentication is the security process of **verifying the identity of a user, device, or application before granting access to a computer system or network**. It ensures that only legitimate users can access protected resources.

Types of Authentication

- **Knowledge-based:** Password, PIN
- **Possession-based:** Smart Card, OTP
- **Biometric-based:** Fingerprint, Face Recognition, Iris Scan

Example: A user logs into their Gmail account using a username, password, and a One-Time Password (OTP) sent to their registered mobile number.

1.2 Threats to Security

1. Virus

A **computer virus** is a malicious software program (malware) that attaches itself to file, program, or boot sector and spreads by copying itself whenever the infected file is executed. It is designed to disrupt computer operations, damage or delete data, steal sensitive information, or reduce system performance.

Phases of a Virus

1. Dormant Phase: The virus enters the system, remains inactive and waits for a specific event or condition before becoming active.

2. Propagation Phase: The virus replicates itself and creates copies that can spread to other files, programs, or storage devices.

3. Triggering Phase: The virus is activated when a predefined condition, event, or action occurs such as date, time or user action.

4. Execution Phase: The virus performs its intended malicious activities which can involve deleting files, corrupting data, or stealing information.

Types of Viruses

A. Types of Viruses Based on Target

1. Boot Sector Virus: A boot sector virus infects the **Master Boot Record (MBR)** or boot sector of a hard disk or USB drive. It becomes active when the computer starts. They are memory-resident viruses.

2. File Infector Virus: A file infector virus attaches itself to executable files such as **.exe** or **.com** files and becomes active when the infected program is executed. They are also called as Parasitic viruses.

3. Macro Virus: A macro virus infects documents that contain macro code, such as **Microsoft Word** or **Excel** files.

B. Types of Viruses Based on Concealment Strategy

1. Encrypted Virus: An encrypted virus encrypts its main body and uses a small decryption routine to execute, making signature-based detection more difficult.

2. Stealth Virus: A stealth virus hides its presence by intercepting system requests and showing false information to users or antivirus software.

3. Polymorphic Virus: A polymorphic virus changes its **code or signature** every time it spreads, making it difficult for antivirus software to detect.

4. Metamorphic Virus: A metamorphic virus completely rewrites its own code each time it infects a new system while keeping the same functionality.

Dealing with Viruses

Methods to prevent virus infection:

- Install antivirus software.
- Update antivirus regularly.
- Scan USB drives.
- Avoid suspicious email attachments.
- Download software from trusted sources.
- Update operating system.
- Take regular backups.

2. Worm

A **worm** is a standalone malicious software (malware) that can **replicate itself and spread automatically** from one computer to another through computer networks without attaching itself to any host program or requiring user action.

Characteristics

- Does not require a host file.
- Self-replicates automatically.
- Spreads through networks.
- Consumes system and network resources.
- Can install other malware.

Example: The **WannaCry Worm** spread rapidly across computers worldwide by exploiting vulnerability in Windows systems.

3. Trojan Horse

A **Trojan Horse** is a type of malware that **disguises itself as legitimate or useful software** to trick users into installing it. Unlike a virus or worm, a Trojan **does not replicate itself**. Once installed, it performs various malicious activities giving attackers remote access to the infected computer.

Characteristics

- Appears as genuine software.
- Requires the user to install or execute it.
- Does not self-replicate.
- Can steal sensitive information.

Example: A fake antivirus program appears to remove viruses but actually installs malware and steals the user's personal information.

4. Intruders

An **intruder** is a person who **gains unauthorized access** to a computer system, network, or database with the intention of stealing information, damaging data, disrupting services, or misusing system resources.

Characteristics

- Gains access without permission.
- Exploits weak passwords or software vulnerabilities.
- May steal, modify, or delete confidential data.

Example: A hacker guesses an employee's password and logs into the company's database to steal customer information.

5. Insiders

An **insider** is an **authorized user**, such as an employee, contractor, or business partner, who intentionally or accidentally misuses their access privileges, resulting in data theft, information leakage, or damage to the organization's systems.

Characteristics

- Has legitimate access to the organization's systems.
- May intentionally or accidentally misuse access privileges.
- Can access sensitive or confidential information.
- Insider attacks are difficult to detect because the user is authorized.

Example: An employee copies the company's confidential customer database onto a USB drive and shares it with a competitor.

6. Ransomware

Ransomware is a type of malicious software that **encrypts or locks a victim's files or computer system** and demands a ransom payment in exchange for restoring access. Even if the ransom is paid, there is no guarantee that the attacker will restore the files.

Characteristics

- Encrypts files or locks devices.
- Demands ransom payment.
- Usually spreads through phishing emails or malicious downloads.

Example: The **WannaCry Ransomware** infected more than 200,000 computers across 150 countries by encrypting users' files and demanding payment in Bitcoin.

Why are Insiders More Dangerous than Outsiders?

Insiders are considered more dangerous than outsiders because they already have authorized access to an organization's systems, data, and resources. This makes it easier for them to misuse information without immediately raising suspicion.

Reasons:

1. Authorized Access

Insiders already have valid usernames, passwords, and permissions, so they do not need to hack into the system.

2. Knowledge of the System

Insiders understand the organization's network, security policies, and locations of sensitive data, making attacks more effective.

3. Difficult to Detect

Since insiders perform actions using legitimate accounts, their malicious activities often appear normal and are harder to identify.

4. Access to Sensitive Information

Insiders can easily access confidential documents, financial records, and customer data.

1.3 Types of Attacks

1. Active Attack

An **Active Attack** is a type of cyberattack in which the attacker actively interacts with the system and modifies, deletes, interrupts, or destroys data or system resources.

Example: A hacker gains access to a college database and changes students' examination marks before the results are announced.

2. Passive Attack

A **Passive Attack** is a type of cyberattack in which an attacker **secretly monitors, or copies information without altering the original data.**

Example: A hacker connects to an unsecured public Wi-Fi network at a café and secretly captures users' usernames and passwords without changing any data.

Difference Between Active and Passive Attack

Active Attack	Passive Attack
Modifies or destroys data	Only monitors data
Affects integrity and availability	Affects confidentiality
Easier to detect	Difficult to detect
Interrupts system operation	Does not interrupt system operation
Example: DoS Attack	Example: Sniffing

3. Denial of Service (DoS) Attack

A **Denial of Service (DoS) attack** is a cyberattack in which a **single attacker floods a server, website, or network with a large number of fake requests**, consuming all available resources and making the service unavailable to legitimate users. The primary objective is to disrupt normal operations rather than steal information.

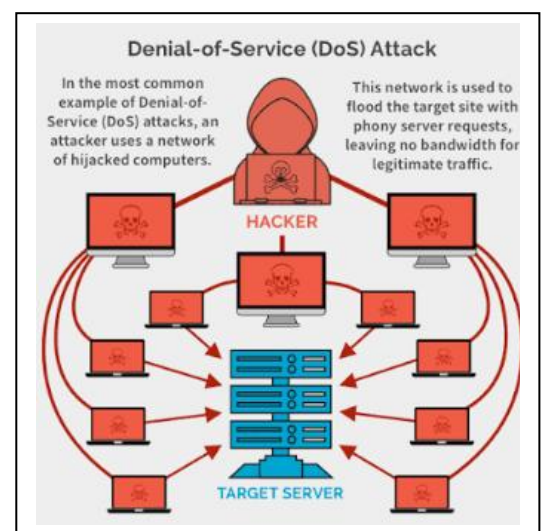
Characteristics

- Launched from a single computer or device.
- Floods the target with excessive traffic.
- Makes services unavailable.
- Slows down or crashes servers.

Example: A hacker continuously sends fake requests to a college admission website on the last day of registration, causing the website to crash.

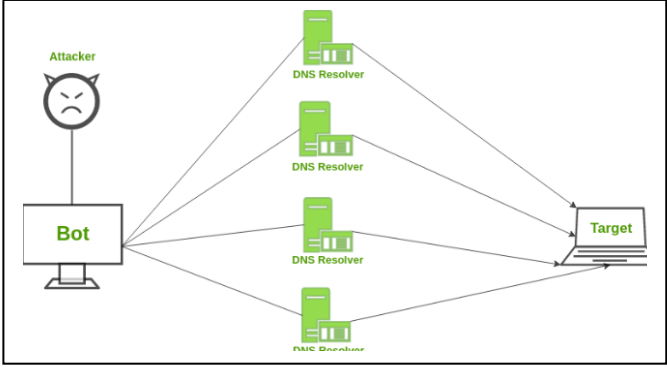
4. Distributed Denial of Service (DDoS) Attack

A **Distributed Denial of Service (DDoS) attack** is an advanced form of DoS attack in which **multiple infected computers (called a botnet)** simultaneously send large amount of requests to a target server, website, or network. Because the attack comes from many different devices, it is much more powerful and difficult to detect or stop than a DoS attack.



Characteristics

- Uses multiple infected computers (botnet).
- Generates extremely high traffic.
- Difficult to identify the real attacker.
- More powerful than a DoS attack.



Example: In **October 2016**, the **Mirai Botnet DDoS attack** targeted the DNS provider Dyn using thousands of infected IoT devices such as CCTV cameras and routers.

5. Backdoor

A **Backdoor** is a **hidden or unauthorized method of bypassing the normal authentication and security mechanisms** of a computer system, application, or network. It allows an attacker to gain direct access to a system without entering the correct username and password

Characteristics

- Bypasses normal authentication.
- Provides hidden or remote access to the system.
- Can be created intentionally or by malware.
- Difficult to detect because it operates secretly.

Example: A hacker installs malware on a company's computer that secretly creates a hidden administrator account. The hacker can later log in remotely without using the normal login process.

6. Trapdoor

A **Trapdoor** is a **secret entry point intentionally left in a software application by developers**. It allows access without following the normal authentication process. While trapdoors may be created for legitimate purposes during software development, they become serious security risks if they are not removed or are discovered by attackers.

Characteristics

- Intentionally created during software development.
- Used mainly for testing or maintenance.
- Bypasses authentication mechanisms.
- May be exploited by attackers.

Example: A software developer leaves a hidden password in an application to simplify testing. After the software is released, an attacker discovers the password and gains unauthorized access.

Difference Between Backdoor and Trapdoor

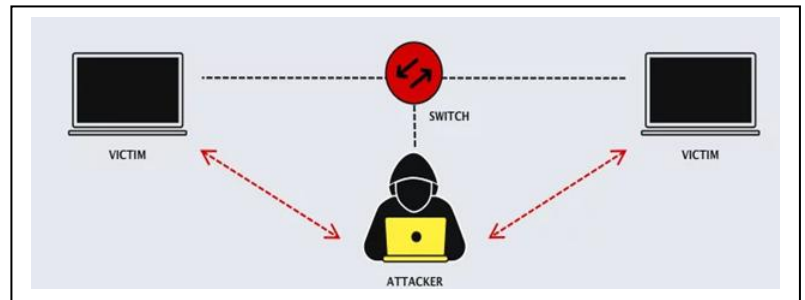
Backdoor	Trapdoor
Usually created by attackers or malware (though sometimes by developers).	Intentionally created by developers during testing or debugging.
Used for unauthorized remote access.	Mainly used for software maintenance or testing.
Mostly malicious.	Initially legitimate but becomes dangerous if left in the software.

7. Sniffing

Sniffing is the process of **capturing, monitoring, and analyzing data packets** travelling across a computer network. Attackers use packet-sniffing tools to collect sensitive information such as usernames, passwords, emails, banking details, and confidential documents. Sniffing is especially dangerous on unsecured or public Wi-Fi networks where data transmission may not be encrypted.

Characteristics

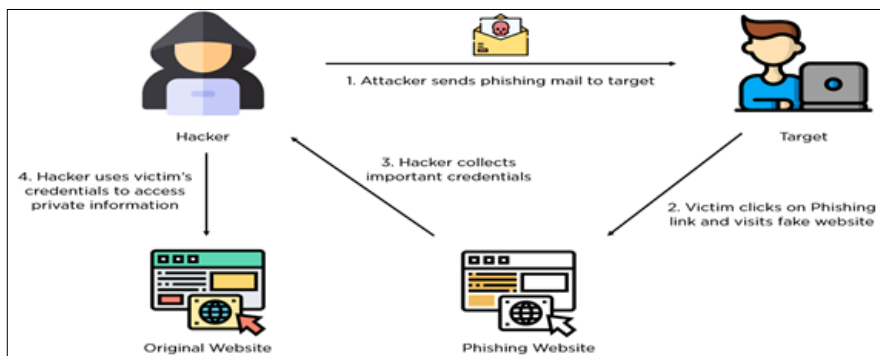
- Captures network traffic.
- Steals sensitive information.
- Can be active or passive.
- Often performed on public Wi-Fi.



Example: A hacker connects to the free Wi-Fi in an airport and captures users' login credentials while they browse unsecured websites.

8. Phishing

Phishing is a **social engineering attack** in which attackers impersonate a trusted organization or person through fake emails, websites, phone calls, or messages to trick users into revealing confidential information such as usernames, passwords, credit card numbers, OTPs, or bank details. It is one of the most common cyberattacks used for identity theft and financial fraud.



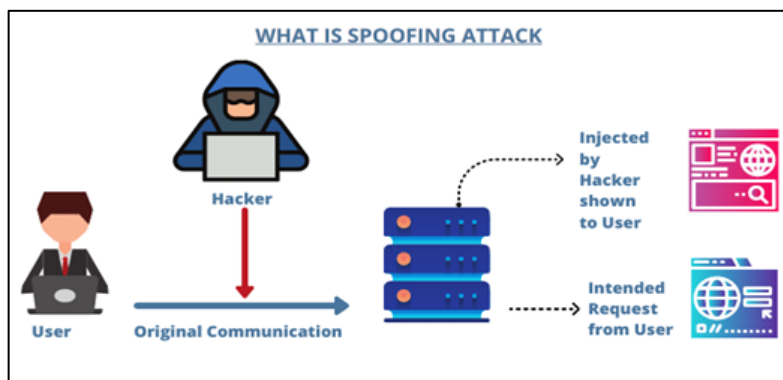
Characteristics

- Uses fake emails, messages, or websites.
- Tricks users into revealing confidential information.
- Appears to come from trusted organizations.
- Targets passwords, OTPs, and banking details.

Example: A user receives an email that appears to be from **State Bank of India (SBI)** asking them to verify their account. The email links to a fake website where the user enters their username, password, and OTP, which are then stolen by the attacker.

9. Spoofing

Spoofing is a cyberattack in which an attacker **pretends to be a trusted user, device, website, email, or network** by falsifying their identity. The main objective of spoofing is to deceive users or systems into revealing confidential information, accepting malicious data, or granting unauthorized access. Spoofing is commonly used in phishing attacks, Man-in-the-Middle (MITM) attacks, and financial fraud.



Characteristics

- Hides the attacker's real identity.
- Impersonates a trusted source.
- Tricks users into revealing confidential information.
- Used to spread malware.

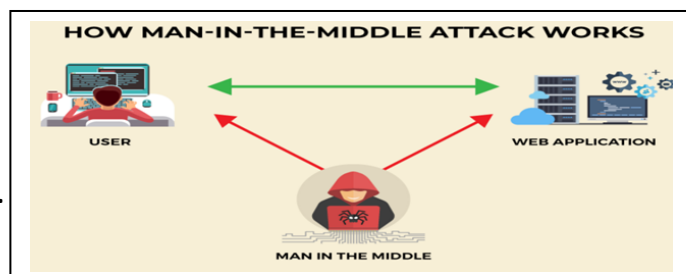
Example: A user receives an email that appears to come from PayPal asking them to verify their account. The email is actually sent by an attacker using email spoofing.

10. Man-in-the-Middle (MITM) Attack

A **Man-in-the-Middle (MITM) attack** is a cyberattack in which an attacker **secretly intercepts, monitors, and sometimes modifies the communication** between two parties who believe they are communicating directly with each other. The attacker positions themselves between the sender and the receiver to steal confidential information such as usernames, passwords, banking details, or personal messages without either party knowing.

Characteristics

- Intercepts communication secretly.
- Can read or modify transmitted data.
- Both parties believe they are communicating directly.
- Often occurs on unsecured public Wi-Fi networks.



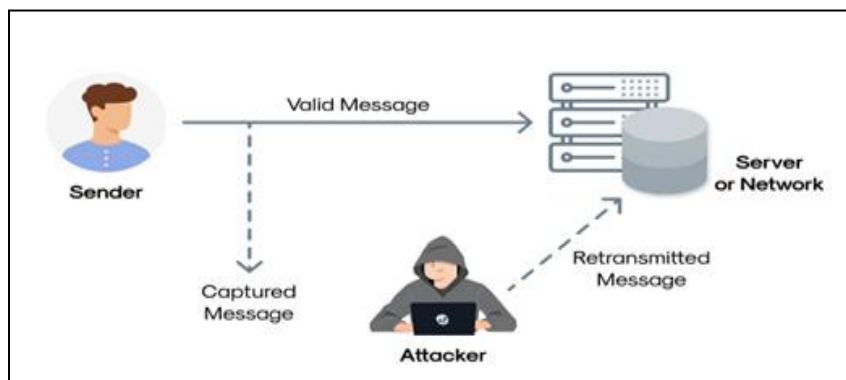
Example: A hacker creates a fake free Wi-Fi hotspot in a shopping mall. When users connect and log in to their online banking accounts, the hacker intercepts their usernames and passwords.

11. Replay Attack

A **Replay Attack** is a network attack in which an attacker **captures valid data packets during communication and retransmits (replays) them later** to gain unauthorized access or perform fraudulent transactions. Since the replayed data appears to be legitimate, the receiving system may accept it as a valid request.

Characteristics

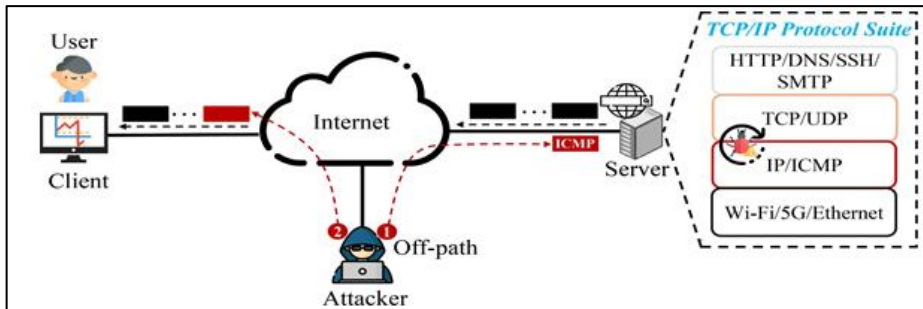
- Captures genuine network packets.
- Reuses valid authentication data.
- Does not require modification of the original message.
- Exploits weak authentication mechanisms.



Example: An attacker captures a valid payment request sent from a customer's mobile banking app and later retransmits the same request, causing the payment to be processed again.

12. TCP/IP Hacking

TCP/IP Hacking refers to the process of **exploiting vulnerabilities in the TCP/IP (Transmission Control Protocol/Internet Protocol)** to gain unauthorized access, steal information, or disrupt network services. Since TCP/IP is the foundation of Internet communication, attackers exploit weaknesses in its protocols to launch various cyberattacks such as IP spoofing, session hijacking, packet sniffing, etc.



Characteristics

- Exploits weaknesses in TCP/IP protocols.
- Targets computer networks and Internet communication.
- Can intercept, modify, or disrupt data transmission.
- Often leads to unauthorized access or denial of service.

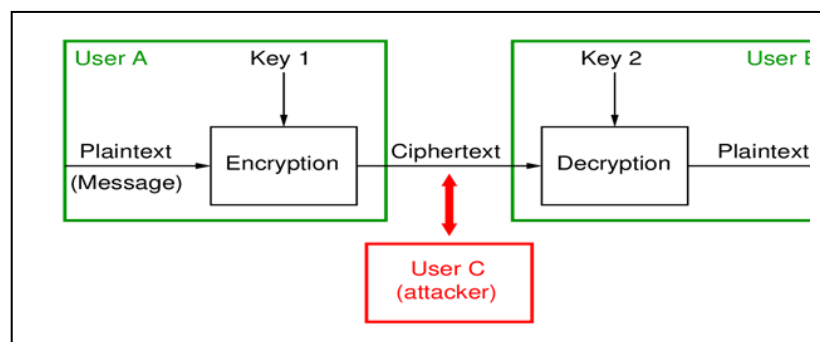
Example: A hacker performs a **Session Hijacking attack** by stealing a user's browser session cookie while they are logged into an online shopping website. The attacker gains access to the victim's account without needing the password.

13. Encryption Attacks

An **Encryption Attack** is a cyberattack in which an attacker **attempts to break, bypass, or decrypt encrypted data without possessing the correct encryption key**. The attacker's objective is to obtain confidential information such as passwords, financial records, personal data, or secret communications. Encryption attacks mainly target weak encryption algorithms, weak passwords, poor key management, or implementation flaws.

Characteristics

- Targets encrypted data.
- Attempts to discover encryption keys.
- Exploits weak encryption methods.
- Can compromise confidential information.



Example: In **2012**, attackers used a **brute-force attack** to guess weak passwords of several online accounts because users had chosen simple passwords like **123456** and **password**. This allowed unauthorized access to personal information.

1.4 Social engineering

Social engineering is the act of tricking or deceiving people into **giving up confidential information or access, usually through trust, fear, urgency, or manipulation.**

Attackers use psychology and manipulation to trick users into performing actions that could compromise with their security including **downloading malicious files, revealing sensitive information, clicking on malicious links, make transactions to illegal sources.**

Example: A person receives a phone call.

Attacker: "I am calling from your bank. Your bank account will be blocked. Please tell me the OTP you have just received."

The person gets scared and shares the OTP. The attacker uses the OTP to withdraw money from the victim's bank account.

Social engineering life cycle:

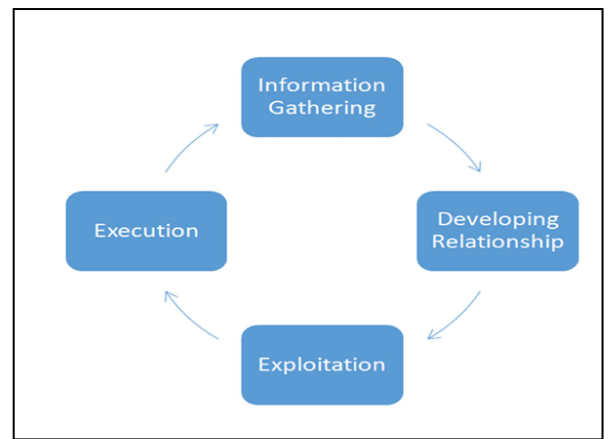
1. Information gathering

In this first stage, the **attacker collects information about the target.** This information may be gathered from social media, company websites, LinkedIn, public records, or conversations.

Purpose:

- Identify the victim.
- Learn personal details, job role, email address, phone number, interests, etc.

Example: An attacker checks a **company's website and LinkedIn profile** to find the names and email addresses of employees.



2. Developing relationship:

The attacker **contacts the victim and builds trust** by pretending to be someone legitimate, such as a bank employee, IT support staff, colleague, or delivery agent.

Purpose:

- Gain the victim's confidence.
- Make the victim believe the attacker is genuine.

Example: The attacker calls an employee saying they are updating his email account.

3. Exploitation:

Once trust is established, the attacker **manipulates the victim into revealing confidential information** or performing an unsafe action.

Purpose:

- Obtain passwords, OTPs, bank details, or confidential data.
- Convince the victim to click a malicious link or download malware.

Example:

The attacker asks the user to share confidential information like username, password, OTP, etc.

4. Execution:

In the final stage, the attacker uses the stolen information to achieve their objective.

Purpose:

- Access accounts or systems.
- Transfer money.
- Install malware.
- Steal confidential data.

Example: Using the stolen OTP, the attacker logs into the victim's bank account and transfers money.

Types of social engineering:**1. Phishing**

Phishing is a social engineering attack in which **attackers impersonate a trusted organization or person** through fake emails, websites, phone calls, or messages to trick users into revealing confidential information such as usernames, passwords, credit card numbers, OTPs, or bank details. It is one of the most common cyberattacks used for **identity theft and financial fraud**.

2. Baiting

Baiting is a type of social engineering attack that **involves leaving a tempting item, such as a USB drive, in a public place in the hope that someone will pick it up and plug it into their computer**. The USB drive is then used to infect the computer with malware.

3. Tailgating

Tailgating is a type of social engineering attack that **involves following an authorized individual into a secure area**, such as a building or data center, without proper authorization.

4. Pretexting

Pretexting is a type of social engineering attack that **involves creating a false identity or situation in order to trick an individual into revealing sensitive information**.

5. Scareware

Scareware is a type of social engineering attack where the **victim is sent false messages claiming their system is infected** with a malware, or outdated, suggesting them to download softwares to resolve the issue. Downloading the software would lead to the attackers gaining access to the system.